

Log Platform — Mappatura controlli tecnici ISO/IEC 27001:2022

Documento generato con Claude

21 agosto 2026

Contents

Scopo del documento	1
A.8 — Controlli tecnologici	2
A.8.1 Dispositivi endpoint utente	2
A.8.2 Diritti di accesso privilegiati	2
A.8.3 Restrizione dell'accesso alle informazioni	2
A.8.5 Autenticazione sicura	2
A.8.9 Gestione della configurazione	2
A.8.10 Cancellazione delle informazioni	2
A.8.12 Prevenzione della perdita dei dati	2
A.8.13 Backup delle informazioni	2
A.8.15 Registrazione degli eventi (log)	2
A.8.16 Attività di monitoraggio	3
A.8.20 Sicurezza delle reti	3
A.8.22 Segregazione delle reti	3
A.8.23 Web filtering	3
A.8.24 Uso della crittografia	3
A.8.25–A.8.29 Ciclo di vita dello sviluppo sicuro	3
A.8.34 Protezione dei sistemi durante il testing	3
A.5 / A.6 / A.7 — Controlli organizzativi, delle persone, fisici	3
Provvedimento Garante Privacy 27/11/2008 — Amministratori di Sistema	3
Nota onesta	4

Scopo del documento

Questo documento mappa i controlli tecnici dell'Allegato A di ISO/IEC 27001:2022 a quanto effettivamente implementato nel codice/configurazione di Log Platform. Non sostituisce un audit di certificazione: è un supporto per prepararlo, e va integrato con `iso27001-politiche-organizzative.docx` per i controlli organizzativi/procedurali che il codice non copre.

Legenda stato: **Implementato** · **Parziale** · **Da definire (organizzativo)**

A.8 — Controlli tecnologici

A.8.1 Dispositivi endpoint utente

Da definire (organizzativo). Fuori dal perimetro tecnico di questa piattaforma (riguarda i dispositivi client, non il server).

A.8.2 Diritti di accesso privilegiati

Parziale. `auth-service` distingue utenti con `tenant = null` (accesso globale/admin) da utenti legati a un singolo tenant. Manca ancora una gerarchia di ruoli più fine (es. sola lettura vs gestione allarmi) — oggi la granularità fine dei permessi va gestita lato Graylog (ruoli nativi Graylog), da configurare manualmente nella UI.

A.8.3 Restrizione dell'accesso alle informazioni

Implementato. Ogni tenant ha uno stream e un index set Graylog dedicati (`scripts/provision-tenant.sh`); il routing avviene sul campo `tenant` impostato dall'agent. Un utente associato a un tenant può essere limitato, lato Graylog, a vedere solo il proprio stream (da configurare nei permessi Graylog per l'utente).

A.8.5 Autenticazione sicura

Implementato. Login con password (hash bcrypt) + MFA TOTP obbligatoria al primo accesso (`auth-service/app/routes.py`). Le sessioni sono token firmati con scadenza configurabile (`SESSION_LIFETIME_MINUTES`). Tentativi di login falliti sono conteggiati e bloccati temporaneamente (`MAX_FAILED_ATTEMPTS` in `routes.py`).

A.8.9 Gestione della configurazione

Parziale. La configurazione dello stack è dichiarativa (`docker-compose.yml`, `.env`) e versionabile. Manca un processo formale di change management: da definire a livello organizzativo.

A.8.10 Cancellazione delle informazioni

Parziale. Gli index set Graylog hanno una retention configurata (`max_number_of_indices` in `provision-tenant.sh`, di default 90 rotazioni giornaliere). La cancellazione sicura del disco cifrato alla dismissione dell'hardware resta una procedura organizzativa.

A.8.12 Prevenzione della perdita dei dati

Parziale. `scripts/backup.sh` copre configurazione e dati utente/MFA. Non copre gli indici OpenSearch (i log) per motivi di spazio: da valutare uno snapshot repository OpenSearch se richiesto dal caso d'uso.

A.8.13 Backup delle informazioni

Implementato. `scripts/backup.sh` (MariaDB, MongoDB/config Graylog, CA, `.env`), pensato per cron giornaliero, con retention configurabile (`BACKUP_RETENTION_DAYS`). `scripts/restore.sh` per il ripristino.

A.8.15 Registrazione degli eventi (log)

Implementato. È il cuore della piattaforma: raccolta centralizzata dei log via GELF/mTLS, ricerca e alerting in Graylog. Per i log di accesso degli amministratori di sistema, vedi anche la sezione dedicata più sotto sul Provvedimento Garante 27/11/2008.

A.8.16 Attività di monitoraggio

Implementato. `scripts/watchdog.sh` verifica lo stato dei container e tenta il riavvio automatico, notificando se un servizio non ripartisce (`WATCHDOG_ALERT_WEBHOOK`). Gli allarmi Graylog sui log dei clienti sono arricchiti dal triage AI (`ai-service`).

A.8.20 Sicurezza delle reti

Implementato. Rete Docker separata per backend/frontend (`docker-compose.yml`). L'input di ingestione log richiede mTLS (certificato client firmato dalla CA interna): un client senza certificato valido non può inviare log.

A.8.22 Segregazione delle reti

Implementato. I servizi interni (MariaDB, MongoDB, OpenSearch) sono sulla rete **backend**, non raggiungibile dall'esterno; solo **nginx** è esposto pubblicamente sulle porte 80/443.

A.8.23 Web filtering

Non applicabile al perimetro di questa piattaforma.

A.8.24 Uso della crittografia

Implementato. - Dati a riposo: volume dati cifrato con LUKS (`setup-encrypted-volume.sh`). - Dati in transito verso gli utenti: TLS su **nginx** (443). - Dati in transito dagli agent: TLS mutuo (mTLS) sull'input GELF. - Password: hash bcrypt; sessioni: token firmati (`itsdangerous`).

A.8.25–A.8.29 Ciclo di vita dello sviluppo sicuro

Parziale. Non c'è ancora una pipeline CI/CD con test di sicurezza automatizzati; da valutare in base alla maturità del progetto.

A.8.34 Protezione dei sistemi durante il testing

Da definire (organizzativo). Serve un ambiente di test separato dalla produzione prima di ogni modifica rilevante.

A.5 / A.6 / A.7 — Controlli organizzativi, delle persone, fisici

Questi controlli (politiche, ruoli e responsabilità, sicurezza delle risorse umane, sicurezza fisica dei locali/datacenter, gestione fornitori, gestione incidenti, continuità operativa, formazione) non sono implementabili nel codice: sono trattati nel documento `iso27001-politiche-organizzative.docx`, da compilare con i dati reali dell'organizzazione.

Provvedimento Garante Privacy 27/11/2008 — Amministratori di Sistema

Requisito distinto da ISO 27001 ma spesso richiesto insieme: conservazione dei log di accesso degli amministratori di sistema per almeno 6 mesi, con garanzia di completezza e non alterabilità.

Implementato tramite un flusso dedicato (non attivo di default, va configurato esplicitamente per ogni tenant che ne ha bisogno):

- `scripts/provision-admin-log-stream.sh`: stream + index set separati, retention configurabile (default 200 giorni, oltre il minimo di 6 mesi).

- Tag `log_class=admin-access` sui log di accesso, impostato dall'agent (`admin_log_files / admin_event_logs` in `agent.ini`), per distinguerli dal resto dei log del tenant.
- `scripts/seal-admin-logs.sh`: sigillo giornaliero via hash chain (SHA-256 concatenato al giorno precedente) + marca temporale RFC 3161 opzionale da una TSA esterna, per garantire l'integrità nel tempo.
- `scripts/verify-admin-log-seal.sh`: verifica la catena e segnala manomissioni o buchi, utile in caso di ispezione.

Limite onesto: `chattr +i` (immutabilità a livello filesystem) non è WORM hardware — un amministratore con accesso root alla macchina che ospita i sigilli potrebbe rimuoverlo. La robustezza reale del meccanismo viene dalla combinazione con la marca temporale esterna (che non è sotto il tuo controllo) e da controlli di accesso rigorosi su quella macchina. Per contesti ad alto rischio legale, valuta una TSA qualificata a pagamento invece di quella di default gratuita, e un parere di un DPO/legale.

Nota onesta

Questa mappatura riflette lo stato del codice al momento della generazione del documento. Non costituisce una certificazione né una garanzia di conformità: per una certificazione reale serve un audit di un ente accreditato, preceduto da un'analisi dei rischi (risk assessment) che qui non è stata svolta.